

Incidente en Sistema Linux 3: Ataque a servidor SSH

Jorge Cortés Hernández

Curso de Especialización de Ciberseguridad en Entornos de las Tecnologías de la Información

Departamento de Informática, CIPFP Cheste

8/12/2025

Índice personalizado

1. Introducción.....	3
2. Objetivos.....	3
2.1 Zona horaria.....	4
2.2 IP del atacante.....	4
2.3 Credenciales de entrada utilizadas.....	5
2.4 Acciones realizadas tras la autenticación por SSH.....	6
2.5 Medidas de seguridad.....	8
3. Conclusión.....	9
4. Recomendaciones Finales.....	10
5. Bibliografía.....	11
6. Firma y Hash.....	11

1. Introducción

El presente informe forense digital analiza una intrusión producida en un sistema operativo Ubuntu que ejecutaba un servicio SSH expuesto a Internet. El ataque identificado corresponde a una campaña de fuerza bruta realizada por un tercero no autorizado, que consiguió acceder al sistema utilizando credenciales válidas.

El informe se ha elaborado a partir de las evidencias proporcionadas: imagen de disco, captura de memoria RAM, perfil de memoria y fichero de hashes.

Para el análisis se ha empleado la herramienta Autopsy, plataforma forense que permite examinar de manera estructurada archivos, logs, metadatos y artefactos del sistema afectado.

Se emplearon también complementos de Autopsy específicos para Linux, que permiten examinar de manera más detallada los ficheros de sistema, directorios de configuración, archivos de registro y otros elementos característicos de este tipo de entornos. Esto resultó clave para extraer información relevante que no es fácilmente accesible desde la interfaz estándar.

2. Objetivos

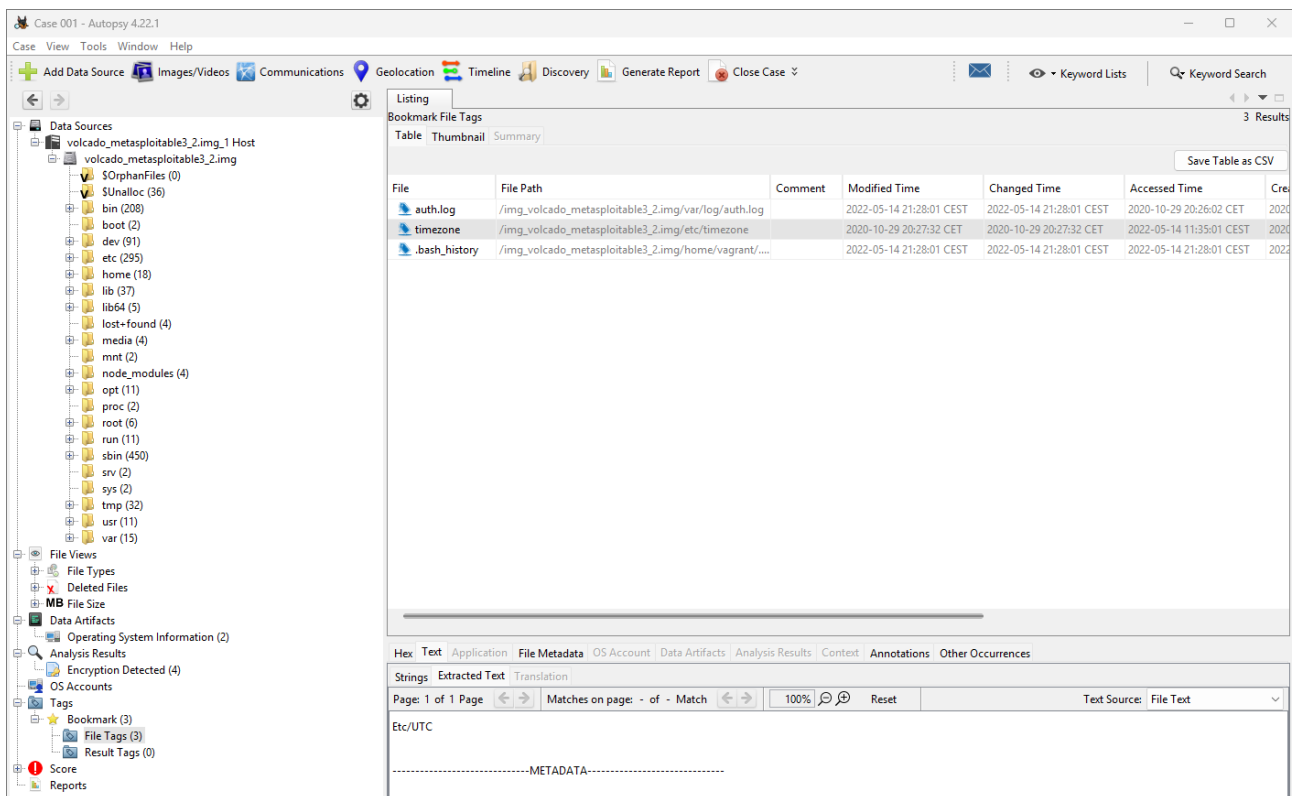
- Determinar la zona horaria configurada en el sistema.
- Identificar la dirección IP del atacante.
- Determinar las credenciales utilizadas para acceder.
- Documentar las acciones realizadas tras comprometer el servidor.
- Proponer medidas de seguridad para evitar ataques similares, especialmente en entornos donde los usuarios continúan utilizando contraseñas débiles

2.1 Zona horaria

El sistema utiliza la zona horaria UTC, según lo reflejado en la configuración del sistema y en las marcas temporales presentes en los registros.

Ilustración 1

Esta imagen muestra el contenido archivo `/etc/timezone`



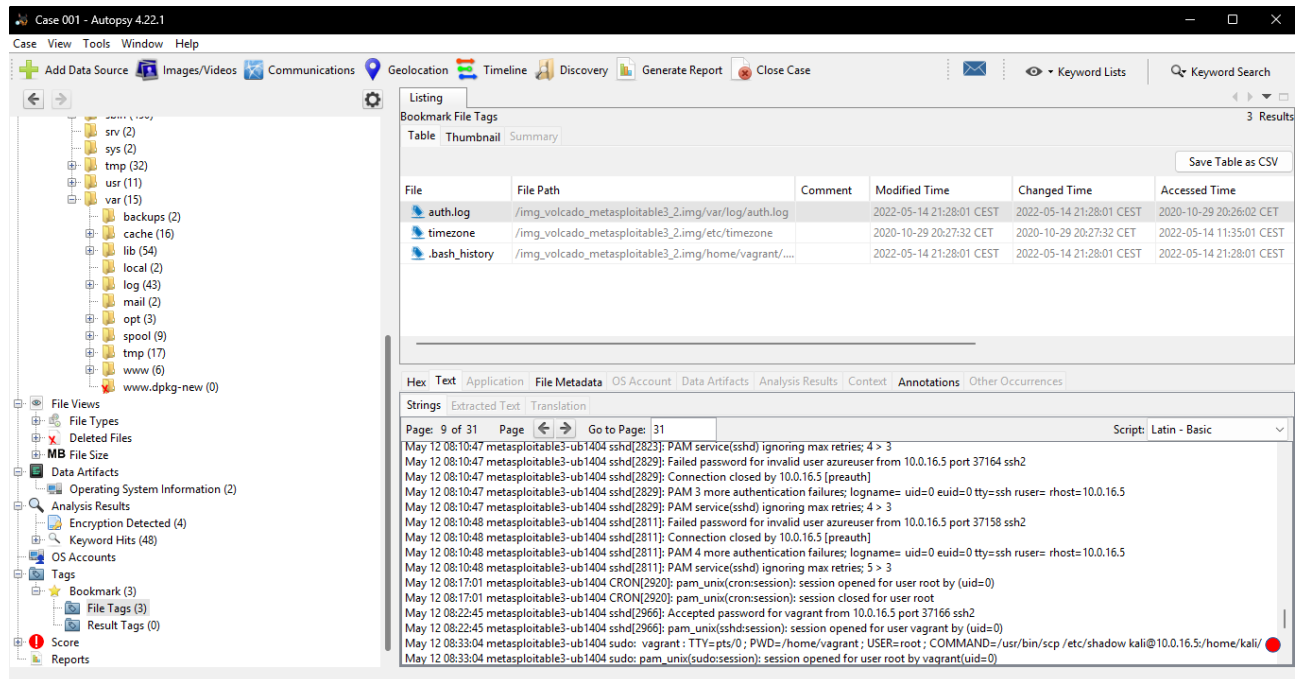
Nota: Elaboración propia

2.2 IP del atacante

El análisis del archivo `/var/log/auth.log` permite identificar que la dirección IP desde la que se originó la intrusión es 10.0.16.5

Ilustración 2

Esta captura de pantalla muestra el contenido del fichero /var/log/auth.log



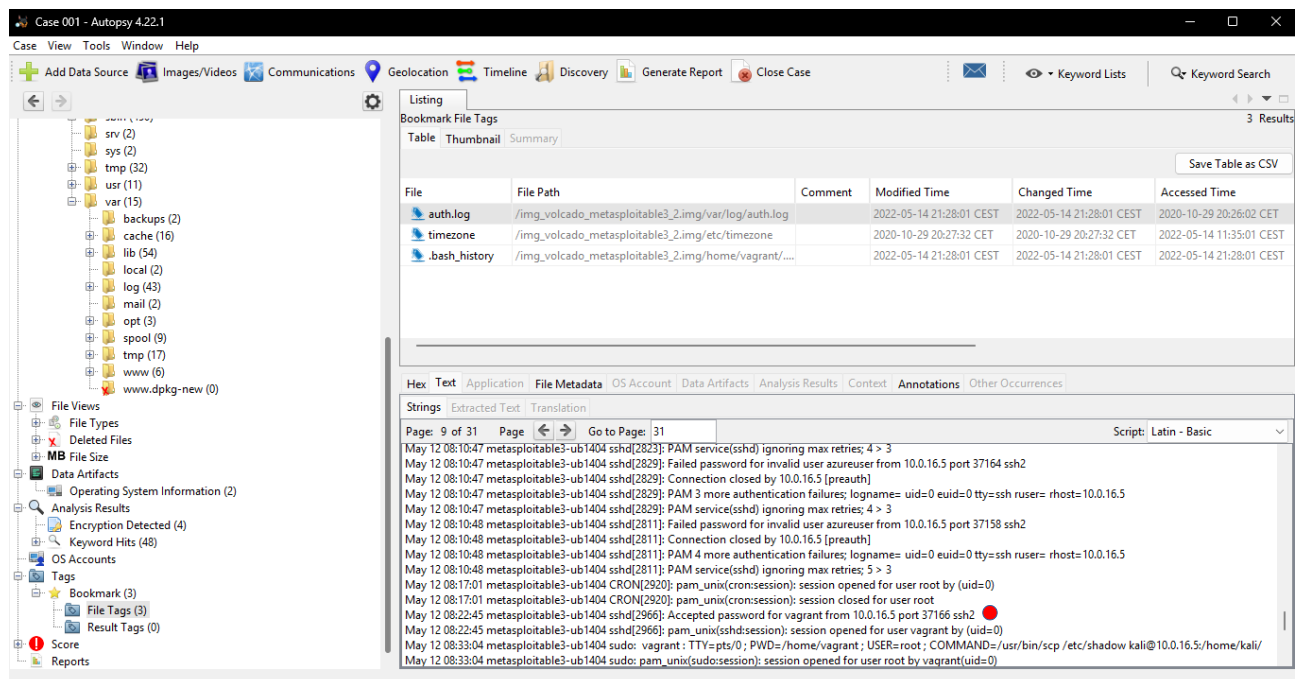
Nota: Elaboración propia

2.3 Credenciales de entrada utilizadas

Del mismo archivo de autenticación se determina que el acceso exitoso al sistema se logró utilizando las credenciales del usuario vagrant.

Ilustración 2

Esta captura de pantalla muestra el contenido del fichero /var/log/auth.log



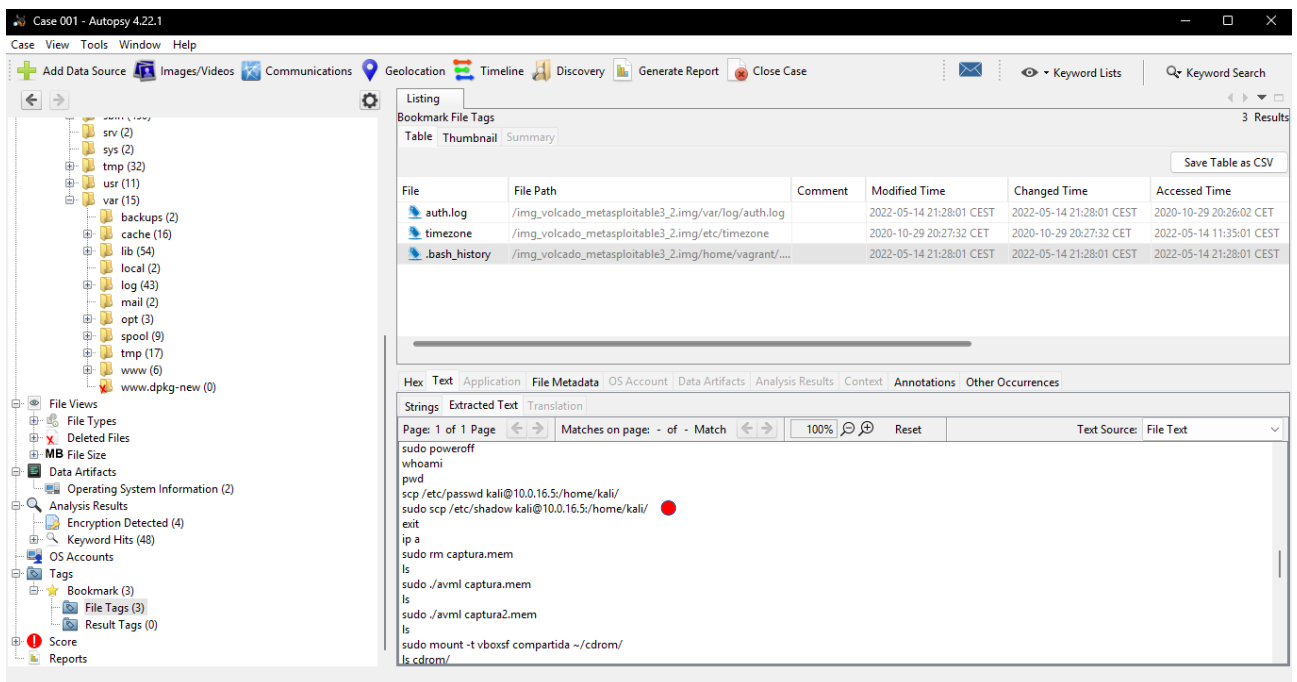
Nota: Elaboración propia

2.4 Acciones realizadas tras la autenticación por SSH

- Después de autenticar correctamente vía SSH, el atacante empleó privilegios elevados mediante *sudo* para realizar varias acciones de impacto: exfiltró el archivo */etc/shadow*.

Ilustración 3

Esta captura de pantalla muestra el contenido del fichero */home/vagrant/.bash_history*

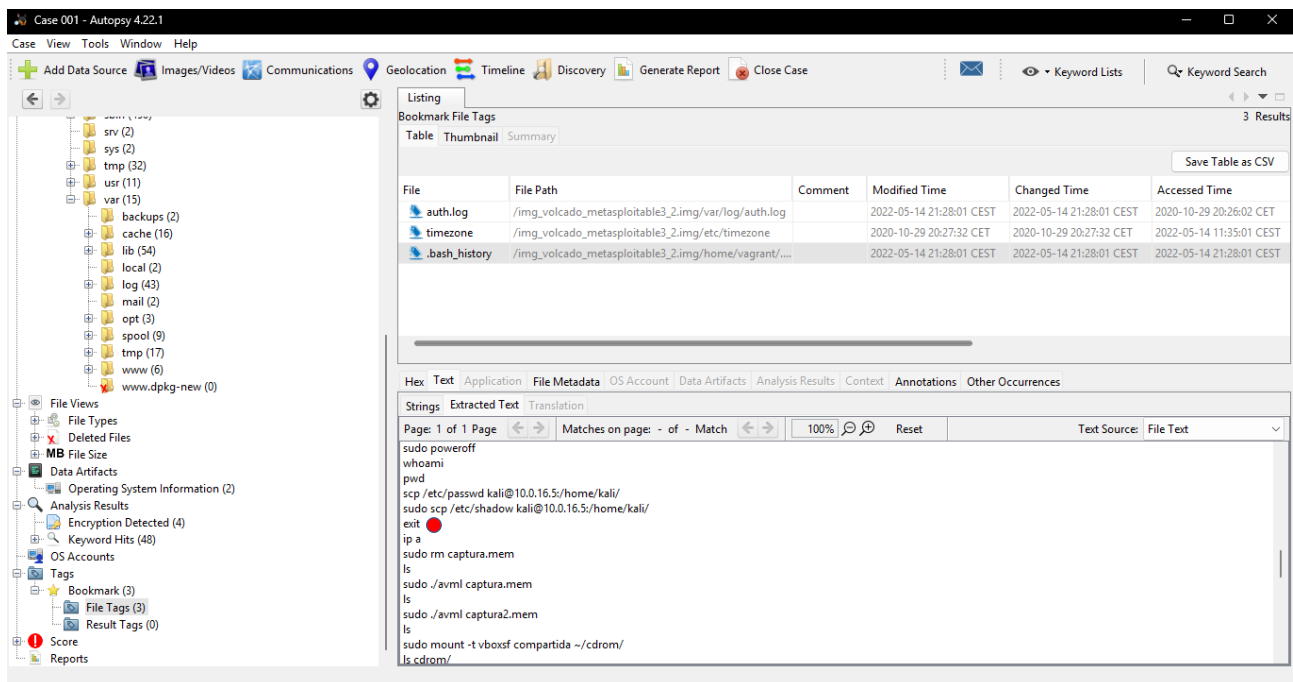


Nota: Elaboración propia

- Finalmente, cerró la sesión y ejecutó apagados del sistema, un patrón que indica una operación centrada en la recolección de información seguida de la interrupción del entorno comprometido.

Ilustración 4

Esta captura de pantalla muestra el contenido del fichero /home/vagrant/.bash_history



Nota: Elaboración propia

2.5 Medidas de seguridad

- La primera medida clave para evitar ataques de fuerza bruta es implementar un sistema de bloqueo automático para impedir que un atacante pueda probar miles de combinaciones, incluso si la contraseña del usuario es débil, cortando así el ataque para evitar que el atacante progrese.
- Otra medida sólida es reducir el uso de contraseñas en SSH, pero entendiendo que no todos los entornos pueden desactivar por completo la autenticación por password. Pudiendo ser aplicadas opciones intermedias muy eficaces como obligar a que solo ciertos usuarios o grupos utilicen autenticación mediante contraseña y que el resto use claves, o permitir contraseñas pero limitar la conexión a través de una VPN interna. Con estas restricciones, incluso si un usuario mantiene una contraseña débil, el atacante no puede explotar ese fallo desde Internet.
- También es recomendable cambiar el puerto por defecto de SSH. No es una protección total, pero reduce en gran medida el ruido de bots automatizados que escanean

sistemáticamente el puerto 22. Menos intentos significa menos exposición y menos carga innecesaria en los registros.

- Otra capa de defensa consiste en limitar qué usuarios pueden usar SSH. Si solo ciertas cuentas están autorizadas a conectarse de forma remota, el resto queda automáticamente fuera del alcance del atacante. En el caso del usuario “vagrant”, que está pensado para entornos de desarrollo y no para producción, lo ideal es deshabilitar su acceso SSH o incluso desactivar la cuenta si no es necesaria.
- Dado que los usuarios suelen ser descuidados con sus contraseñas, es necesario añadir controles técnicos que no dependan de ellos. Esto incluye políticas mínimas de complejidad, impedir el uso de contraseñas del diccionario y bloquear temporalmente una cuenta tras varios intentos fallidos. Aunque estas medidas no frenan todos los ataques de fuerza bruta, dificultan notablemente su éxito y reducen el riesgo.
- Por último, es fundamental evitar configuraciones de sudo demasiado permisivas, como permitir que ciertos usuarios ejecuten comandos privilegiados sin volver a solicitar contraseña. Si un atacante logra entrar a esa cuenta, tendrá acceso inmediato a privilegios de administrador. Exigir siempre credenciales para sudo y limitar los comandos permitidos reduce el impacto de una posible intrusión.

3. Conclusión

El análisis forense de la máquina comprometida evidencia que el atacante logró acceder mediante fuerza bruta al usuario vagrant el día 12 de mayo de 2022 desde la IP 10.0.16.5. Una vez obtenido acceso, utilizó permisos de sudo para elevar privilegios a root, lo que le permitió ejecutar herramientas como `avm1` para capturar la memoria del sistema y transferir archivos sensibles, incluyendo `/etc/shadow`, hacia un equipo externo. Las acciones realizadas

por el atacante indican un compromiso completo del sistema, incluyendo la posibilidad de borrar o modificar registros para ocultar su actividad. Aunque no se observan indicios de persistencia avanzada, la facilidad con la que se accedió al sistema demuestra que la seguridad basada únicamente en contraseñas débiles es insuficiente. Este incidente resalta la necesidad de implementar controles más robustos para proteger tanto el acceso remoto como la integridad de la información sensible en el sistema.

4. Recomendaciones Finales

Para prevenir futuros compromisos, se recomienda implementar varias medidas de seguridad complementarias. En primer lugar, se debe restringir el acceso SSH mediante el uso exclusivo de claves públicas, deshabilitando el inicio de sesión con contraseñas para reducir el riesgo de ataques de fuerza bruta. Además, es fundamental mantener el sistema actualizado, aplicar parches de seguridad de manera regular y restringir el uso de sudo solo a usuarios confiables. La instalación de herramientas de monitoreo y detección de intrusiones, como OSSEC o Wazuh, permitirá alertar ante actividades sospechosas. Se aconseja también limitar el acceso SSH a rangos de IP confiables o a través de VPN, configurar un firewall que bloquee puertos innecesarios y rotar regularmente contraseñas y claves de acceso. Finalmente, se recomienda realizar copias de seguridad periódicas y revisar la integridad de los archivos críticos mediante herramientas como Tripwire o AIDE, asegurando así que cualquier manipulación no autorizada pueda detectarse de forma temprana. Implementando estas medidas, se reduce significativamente el riesgo de que un atacante pueda repetir el mismo tipo de intrusión.

5. Bibliografía

- Barrett, D., & Silverman, R. (2012). SSH, [*The Secure Shell: The Definitive Guide*](#). O'Reilly Media.
- National Institute of Standards and Technology (NIST). (2022). [*Guide to Computer Security Log Management*](#)
- OpenSSH. (2022). [*OpenSSH Manual Pages*](#).

6. Firma y Hash

pSuFWxJ5rPSQ46gP/onoljmbDfqC9tR38Bcl4V41V3k=